INTERNATIONAL CYBERSECURITY &
DIGITAL FORENSICS ACADEMY

AICS-201

AI Governance & Risk Management

Task 2 — Individual Case-Based Practical Assessment

Case organisation
SecureFinance Africa (fictional fintech organisation)

Framework applied
NIST Artificial Intelligence Risk Management Framework (AI RMF 1.0)

Assessment weighting
25 marks

Prepared as a proposed pre-deployment governance assessment. Organisational roles, risk ratings and controls are analytical recommendations unless expressly identified as facts in the assessment brief.

Prepared: 11 November 2026

Submission format: PDF report with supporting risk-register CSV

Document control

Field	Details
Assessment	AICS-201 — AI Ethics, Governance & Legal Frameworks
Task	Task 2 — AI Governance and Risk Management
Case	SecureFinance Africa (fictional)
Assessment basis	ICDFA Assessment 01 brief; NIST AI RMF 1.0
Status	Proposed governance design; not an audit of a live system
Data status	No real customer records or production data used

Executive summary

This report proposes an AI governance and risk-management framework for SecureFinance Africa, a fictional financial technology organisation developing an AI-powered platform for customer identity verification, fraud detection and automated financial risk assessment. The assessment brief states that the platform processes personal information, analyses transaction patterns, flags potentially suspicious activity and recommends decisions that could affect customers. Initial deployment is planned in Nigeria, with possible future international expansion.

The proposed approach applies the four functions of the NIST AI Risk Management Framework (AI RMF 1.0): GOVERN, MAP, MEASURE and MANAGE. It establishes governance responsibilities, identifies risks across the AI lifecycle, defines a qualitative likelihood-and-impact method, proposes risk treatments and monitoring indicators, and establishes human oversight and incident-escalation arrangements.

A ten-item risk register is provided, exceeding the assessment minimum of eight risks. The highest inherent risks are algorithmic bias and unfair financial outcomes, each provisionally rated Critical. Privacy, human oversight, cybersecurity, data integrity, model drift, explainability, third-party dependencies and incident response are also assessed. Ratings are preliminary analyst judgements because the case brief does not provide model architecture, training data, operational metrics, existing controls or incident history.

The report recommends that SecureFinance Africa should not proceed directly to unrestricted production deployment. A controlled pilot may be considered only after critical risks have been treated, controls have been tested, human review is operational for consequential decisions, and authorised governance roles approve the residual-risk position.

Key conclusion: this report proposes a governance design; it does not establish that the fictional organisation is compliant, that controls already exist, or that the AI platform has demonstrated acceptable performance.

Contents

- 1. Purpose, scope and case assumptions
- 2. Framework selection and application
- 3. Governance structure and accountability
- 4. Risk identification and assessment method
- 5. Risk measurement and scoring
- 6. Risk treatment and mitigation
- 7. Continuous monitoring
- 8. Human oversight
- 9. Incident escalation and response
- 10. AI risk register
- 11. Deployment gates and risk acceptance
- 12. Implementation roadmap and evidence

- 13. Limitations and conclusion
- References
- Appendix A — Risk register data dictionary
- Appendix B — AI-assisted work declaration template

1. Purpose, scope and case assumptions

1.1 Purpose

The purpose of this report is to propose an organisational approach for governing and managing risks associated with the proposed SecureFinance Africa AI platform before deployment. It responds to Task 2 of the AICS-201 assessment by addressing governance responsibilities, risk identification, risk measurement, mitigation, monitoring, human oversight and incident escalation.

1.2 System scope

Scope element	Assessment description
Identity verification	AI-supported assessment of customer identity information. The precise verification method is not specified.
Fraud detection	Analysis of transaction patterns and generation of potentially suspicious-activity flags.
Financial risk assessment	Generation of financial risk assessments or recommendations that may affect customers.
Data	The brief identifies personal information and transaction-pattern data; exact fields, sources, retention periods and data flows are unknown.
Deployment context	Nigeria is the planned initial deployment jurisdiction; international expansion is possible but not confirmed.
Decision authority	The brief does not establish whether outputs are advisory, semi-automated or fully automated. This report recommends meaningful human review for consequential decisions.

1.3 Assumptions and boundaries

The organisation, platform and deployment scenario are fictional. This report does not assess a live production system, inspect source code, validate a model, process real customer data or verify existing organisational controls. It does not assume that any named governance role or committee already exists. Roles such as Chief Risk Officer (CRO), Chief Technology Officer (CTO), Chief Information Security Officer (CISO), Data Protection Officer (DPO) and AI Governance Committee are proposed designations.

The assessment also does not assume a specific algorithm, model provider, cloud environment, training dataset, feature set, decision threshold or transaction volume. These are information gaps that should be resolved during system mapping and due diligence.

1.4 Scope exclusions

Detailed legal interpretation is reserved for Task 3. Empirical fairness calculations and explainability experiments are reserved for Task 4, which requires a synthetic dataset or documented fictional example. This Task 2 report identifies governance requirements and the evidence that should be collected; it does not fabricate model-performance or fairness results.

2. Framework selection and application

2.1 NIST AI RMF 1.0

The NIST AI Risk Management Framework (AI RMF 1.0) is selected as the organising framework because it provides a lifecycle-oriented structure for incorporating trustworthiness considerations into the design, development, deployment, use and evaluation of AI systems. Its four functions are GOVERN, MAP, MEASURE and MANAGE. They are interconnected and iterative, not a one-time linear checklist.

Function	Purpose	SecureFinance Africa application
GOVERN	Establish policies, accountability, culture and oversight.	AI policy, system inventory, named risk owners, committee oversight, risk appetite, staff competence and independent assurance.
MAP	Understand context, intended purpose, stakeholders and potential impacts.	Document system boundaries, data flows, use cases, affected customers, decision pathways, third parties and foreseeable harms.
MEASURE	Assess, analyse and track AI risks using appropriate methods and evidence.	Likelihood-impact scoring, performance validation, fairness evaluation, privacy/security assessment, drift indicators and control testing.
MANAGE	Prioritise and respond to assessed risks, including monitoring and treatment.	Mitigation plans, restrictions on unsafe use, human review, incident response, residual-risk approval and deployment gates.

2.2 How the framework should be used

GOVERN establishes who is accountable and the rules under which the system may operate. MAP then creates a defensible understanding of the system and its context. MEASURE evaluates identified risks through qualitative analysis and technical or operational evidence. MANAGE selects and implements responses, tracks residual risk and informs decisions to deploy, restrict, modify or discontinue an AI function. Monitoring and new evidence should feed back into MAP and MEASURE.

NIST AI RMF is a voluntary framework. It supports risk-management practice but does not replace applicable legislation, regulatory guidance, contractual duties or professional obligations. Legal applicability is assessed separately in Task 3.

3. Governance structure and accountability

3.1 Governance principles

Principle	Proposed application
Accountability	Every material AI risk has an accountable owner and an escalation route.
Transparency	System purpose, limitations, material changes and decision rationale are documented.
Fairness	Outcomes and error rates are evaluated across relevant customer groups; unjustified disparities trigger investigation.
Privacy	Personal information is processed under defined purposes, access restrictions and retention rules.
Security and resilience	Models, data pipelines, APIs, infrastructure and suppliers are protected and monitored.
Human oversight	Qualified personnel can understand, challenge, override and escalate consequential AI outputs.
Continuous improvement	Risk assessments are refreshed after material changes, incidents or monitoring signals.

3.2 Roles and responsibilities

Role	Core responsibilities	Accountability
Board / Executive Management	Approve AI risk appetite, resources, policy and major deployment decisions.	Overall organisational accountability.
AI Governance Committee	Review material risks, approve governance standards, monitor actions and review deployment readiness.	AI governance oversight.
Chief Risk Officer (CRO)	Coordinate enterprise AI risk assessment, treatment, risk reporting and risk acceptance.	AI risk management.
Chief Technology Officer (CTO)	Oversee architecture, infrastructure, reliability, technical controls and operational readiness.	Technology delivery.
AI / ML Lead	Manage model lifecycle, documentation, validation, performance and drift monitoring.	Model lifecycle.
Data Protection Officer (DPO)	Advise on personal data governance, privacy risks and data protection incident assessment.	Privacy oversight.
CISO	Manage cybersecurity controls, access, vulnerability handling, security monitoring and response.	Information security.
Compliance / Legal Officer	Interpret applicable obligations, maintain compliance evidence and coordinate regulatory advice.	Legal and regulatory oversight.
Fraud Operations Manager	Manage fraud workflows, reviewer capacity, case escalation and operational feedback.	Fraud operations.
Human Decision Reviewer	Review relevant cases, challenge outputs, override where justified and record rationale.	Individual case review.
Internal Audit	Independently assess governance design and control effectiveness.	Independent assurance.

3.3 Separation and independence

The model development team should not be the sole party validating or approving its own consequential model. Independent validation should be performed by a suitably qualified reviewer who is sufficiently separate from development. Internal Audit should retain independence from the day-to-day operation of controls it assesses. The DPO and Compliance / Legal functions should be able to escalate concerns without being overridden by delivery deadlines.

3.4 Decision rights

Decision	Proposed authority
Approve AI policy and risk appetite	Board / Executive Management
Approve governance standards and controlled-pilot recommendation	AI Governance Committee
Validate technical performance	AI / ML Lead plus independent qualified reviewer
Accept material residual risk	Authorised executive risk authority, subject to legal restrictions
Suspend an affected AI function	Pre-authorised incident authority or designated executive
Override an individual recommendation	Authorised human decision reviewer
Approve material model changes	AI Governance Committee after appropriate validation

No business owner should accept a risk in a way that bypasses mandatory legal requirements or non-negotiable privacy and security controls.

4. Risk identification and system mapping

4.1 Lifecycle coverage

Risk identification should cover the full AI lifecycle: data sourcing and collection; data preparation and labelling; model design and training; testing and validation; integration and deployment; operational use; monitoring and maintenance; material modification; and retirement. Risk identification should include technical, ethical, privacy, security, operational, third-party and organisational dimensions.

4.2 System context record

Context area	Questions and evidence to obtain
Intended purpose	What exact decisions or recommendations does each AI function support? What uses are prohibited?
Users and affected parties	Which employees, customers, applicants, counterparties and other stakeholders interact with or are affected by outputs?
Inputs and provenance	What personal, identity and transaction data are used? What are their sources, quality, lawful basis and permitted purposes?
Outputs and actions	Does the system generate scores, flags, recommendations or automated actions? Who acts on each output?
Automation level	Can an output directly deny, restrict, delay or escalate a customer transaction or service?
Dependencies	Which cloud, model, identity, data and monitoring suppliers are involved?
Operating context	What are the expected volumes, languages, customer segments, operating hours and failure modes?
Change management	Who can change features, thresholds, prompts, model versions or deployment configurations?

4.3 Stakeholder and harm analysis

The MAP activity should examine foreseeable impacts on customers with limited financial histories, customers from underrepresented regions, people with inconsistent identity records, fraud analysts, customer support teams, compliance personnel, regulators and business partners. The assessment should consider not only average model performance but also how errors are distributed and how easily affected people can obtain review or correction.

4.4 Initial risk taxonomy

Risk category	Illustrative risk for this case
Fairness and bias	Unequal error rates or unjustified differences in identity verification or financial recommendations.
Privacy and data governance	Excessive collection, incompatible reuse, weak retention or unauthorised disclosure.
Reliability and validity	Incorrect flags, false rejection, missed fraud or unstable model behaviour.
Transparency and explainability	Inability to explain material factors, limitations or reasons for a recommendation.
Human factors	Automation bias, inadequate reviewer training or ineffective appeals.
Cybersecurity	Credential compromise, data poisoning, model extraction, API abuse or infrastructure attack.
Data quality	Incomplete, stale, inaccurate or inconsistently labelled inputs.
Third-party risk	Supplier outages, weak controls, opaque subcontracting or unclear incident responsibilities.
Operational resilience	Inadequate fallback, rollback, incident handling or business continuity.
Governance failure	Unclear ownership, undocumented changes or unapproved expansion of intended use.

5. Risk measurement and scoring

5.1 Qualitative scoring method

Because the case brief supplies no operational data, this report uses a transparent qualitative method for initial prioritisation. Each risk is scored for likelihood and impact on a five-point scale. The scores are analyst estimates for planning, not measured probabilities or evidence of actual incidents.

Score	Likelihood	Definition
1	Rare	Unlikely under normal operating conditions.
2	Unlikely	Could occur, but is not expected frequently.
3	Possible	May occur under foreseeable conditions.
4	Likely	Expected in some operational circumstances.
5	Almost certain	Expected to occur frequently or repeatedly.

Score	Impact	Definition
1	Insignificant	Minimal operational effect, quickly corrected.
2	Minor	Limited customer or operational impact.
3	Moderate	Material disruption or customer harm requiring intervention.
4	Major	Significant customer, financial, legal or operational consequences.
5	Severe	Widespread or critical harm, major regulatory exposure or serious financial consequences.

5.2 Calculation and rating bands

Inherent risk score = Likelihood × Impact. The same formula is used for residual risk after controls, using the estimated remaining likelihood and impact.

Score	Proposed rating	Interpretation
1–4	Low	Manage through routine controls and monitoring.
5–9	Moderate	Document treatment and monitor control performance.
10–16	High	Require active mitigation, accountable management review and escalation.
17–25	Critical	Do not proceed with the affected use until substantial remediation and reassessment.

These rating thresholds are proposed for this assessment; they are not prescribed by NIST AI RMF. The organisation should approve and calibrate its own risk appetite.

5.3 Quantitative and operational indicators

Risk area	Candidate measure	Purpose
Identity verification	False acceptance rate; false rejection rate; manual referral rate.	Understand erroneous acceptance and rejection patterns.
Fraud detection	Precision; recall; false alert rate; missed-event rate.	Balance detection capability with unnecessary customer disruption.
Fairness	Group-level selection rates; false positive and false negative rates; relevant error-rate differences.	Detect possible disparities requiring contextual investigation.
Privacy	Unauthorised access events; data incidents; retention exceptions.	Assess privacy-control operation.
Security	Critical vulnerabilities; unresolved security findings; incident frequency.	Track technical exposure and remediation.
Explainability	Share of consequential decisions with a recorded reason and reviewable evidence.	Assess decision traceability.
Human oversight	Review completion; override rate; appeal outcomes; overdue cases.	Assess whether review is real and effective.
Model drift	Feature distribution changes; prediction shifts; performance change.	Detect changing operating conditions.

Measures must be interpreted in context. A higher override rate, for example, is not automatically evidence of failure; it may reflect effective human challenge or poor model quality. Each indicator needs a defined owner, baseline, data source, threshold rationale and escalation action.

5.4 Validation and evidence

Before production use, the model owner should produce validation evidence using data that is appropriate to the intended population and use. Evidence should include data quality, representative coverage, performance by relevant groups, robustness, explainability or decision review, security testing and known limitations. Where real data cannot be used in the academic assessment, the fairness demonstration in Task 4 should use synthetic data and must be clearly labelled as illustrative.

6. Risk treatment and mitigation

6.1 Treatment options

Treatment	Meaning	Illustrative application
Mitigate	Reduce likelihood or impact through controls.	Fairness testing, access controls, validation, human review and monitoring.
Avoid	Do not undertake an unsafe or unjustified activity.	Do not use an unvalidated model as the sole basis for a consequential adverse decision.
Share / transfer	Allocate defined responsibilities contractually while retaining appropriate oversight.	Supplier security obligations, audit rights, service commitments and incident cooperation.
Accept	Formally accept a remaining risk within approved appetite.	Accept a low residual operational risk with a named owner and monitoring.

Risk acceptance does not remove legal obligations or make an unsafe practice acceptable. Where the impact could be severe, the preferred response should be additional mitigation, restriction or avoidance until the risk is reduced.

6.2 Control design principles

Controls should be specific, testable and proportionate. A policy statement is not sufficient evidence that a control works. For each control, the organisation should document the control objective, accountable owner, implementation status, operating frequency, evidence produced, testing method, failure response and residual risk.

6.3 Priority treatment plan

Priority	Risk focus	Minimum proposed action before affected use
P1	Bias and unfair outcomes	Validate data coverage; test relevant group outcomes and error rates; review features and thresholds; establish remediation and human review.
P1	Privacy and security	Map data flows; apply data minimisation, access control, encryption, retention and security monitoring; assess suppliers and incident readiness.
P1	Human oversight	Define decision authority, reviewer training, override and appeal processes; test that reviewers can act independently.
P2	Transparency and traceability	Document intended use, limitations, model version, material factors and decision rationale; retain appropriate audit logs.
P2	Data quality and model drift	Introduce input validation, data lineage, baseline metrics, drift detection and revalidation triggers.
P2	Third-party and incident readiness	Complete supplier due diligence, contract controls, escalation contacts, containment plans and tabletop exercises.

7. Continuous monitoring

7.1 Monitoring approach

Monitoring should cover model outcomes, input data, fairness, security, privacy, human review, supplier performance and governance actions. Results should be reviewed at a frequency proportionate to risk and reported to the AI Governance Committee. Material changes, incidents or unexpected outcomes should trigger an out-of-cycle reassessment.

Area	Indicator	Proposed starting frequency	Owner
Model performance	Precision, recall, false positives and false negatives.	Monthly; more frequently during pilot if volume permits.	AI / ML Lead
Fairness	Group-level outcome and error-rate differences.	Monthly and after material data/model changes.	AI / ML Lead / CRO
Data quality	Missingness, anomalies, schema changes and distribution shifts.	Weekly or per data release.	Data Governance Lead
Model drift	Feature and prediction distribution changes; performance movement.	Monthly; automated alerts where feasible.	AI / ML Lead
Security	Access anomalies, critical vulnerabilities and suspicious API activity.	Continuous detection; scheduled review.	CISO
Privacy	Access exceptions, retention failures and personal data incidents.	Continuous detection; scheduled review.	DPO
Human oversight	Review completion, override patterns and unresolved cases.	Monthly.	Fraud Operations Manager
Governance	Open high risks, overdue remediation and unapproved changes.	Quarterly and at each approval gate.	CRO / AI Governance Committee

The frequencies above are proposed starting points, not deadlines imposed by the assessment brief or NIST. They should be adjusted for transaction volume, risk severity, model behaviour and operational capacity.

7.2 Example monitoring triggers

- A material deterioration in model performance against an approved baseline.
- An unexplained disparity in outcome or error rates between relevant customer groups.
- A suspected personal data breach or unauthorised access event.
- A sharp increase in false fraud alerts or identity verification failures.
- A material change in data sources, features, thresholds, model version or intended purpose.
- A failure of human review, customer challenge or escalation processes.
- A critical vulnerability, model manipulation signal or supplier control failure.

7.3 Change management

Material changes to training data, features, model architecture, thresholds, third-party services, operating environment or intended use should be documented and assessed before release. The change record should identify the reason, impact analysis, testing evidence, approvals, rollback plan and updated risk-register entries. A model should not be silently repurposed beyond its approved scope.

8. Human oversight

8.1 Oversight objective

Human oversight is intended to prevent uncritical reliance on AI outputs where those outputs may materially affect customers. Reviewers must have adequate competence, relevant information, time, authority and a practical ability to challenge or override recommendations. A nominal human sign-off without meaningful scrutiny is not an effective control.

8.2 Proposed workflow

Stage	Activity	Required safeguard
1. Input	Customer or transaction information enters the approved workflow.	Validate data quality, access permissions and intended purpose.
2. AI processing	The model generates an identity result, fraud flag or financial risk recommendation.	Record model version, timestamp and relevant input/output metadata.
3. Triage	Output is classified by impact, confidence and uncertainty under approved rules.	Do not treat model confidence as proof of correctness.
4. Human review	A qualified reviewer examines relevant evidence and limitations.	Provide meaningful information and authority to challenge.
5. Decision	Authorised personnel accept, modify, reject or escalate the recommendation.	Record rationale and decision-maker.
6. Feedback	Outcome and review information feed monitoring and quality processes.	Control feedback quality; avoid unreviewed feedback loops.

8.3 Oversight by use case

AI function	Proposed human oversight
Identity verification	Manual review for uncertain, inconsistent or consequential verification outcomes; provide a correction route for inaccurate source information.
Fraud detection	An AI flag should support investigation rather than automatically establish wrongdoing. Human investigation should precede consequential adverse action.
Financial risk assessment	Qualified personnel should review consequential recommendations, consider relevant context and retain decision accountability.

8.4 Reviewer safeguards

- Training on model purpose, limitations, error patterns, bias and automation bias.
- Access to relevant supporting evidence and an explanation appropriate to the decision.
- Authority to override, defer or escalate an AI recommendation.
- Workload and time sufficient for genuine review.
- Documented reasons for material overrides or unusual acceptance patterns.
- A customer-facing process to challenge or correct consequential decisions, as appropriate.
- Periodic quality assurance of reviewer decisions and consistency.

9. Incident escalation and response

9.1 AI incident definition

For this proposed framework, an AI incident is an event involving actual or suspected failure, misuse, compromise or harmful behaviour of the AI system or its supporting controls. Examples include systematic discriminatory outcomes, serious model degradation, incorrect identity verification at scale, unauthorised personal data access, data poisoning, model manipulation, repeated harmful false alerts, unauthorised model changes or failure of human oversight.

9.2 Proposed severity levels

Level	Classification	Illustrative example	Response expectation
SEV-1	Critical	Confirmed major data breach, widespread harmful model behaviour or critical compromise.	Immediate escalation; contain and consider suspending affected functionality.
SEV-2	High	Material fairness failure or repeated incorrect consequential outputs.	Urgent investigation; restrict affected use and notify senior owners.
SEV-3	Medium	Localised performance degradation or recurring operational errors.	Assigned corrective action and management escalation.
SEV-4	Low	Minor documentation or process issue without material observed harm.	Routine remediation and tracking.

These are proposed internal severity categories and are not NIST-prescribed classifications. Legal notification criteria and deadlines must be assessed separately under applicable law.

9.3 Escalation and response sequence

Step	Required action	Primary responsibility
1. Detect and report	Identify event, record time, affected function and initial indicators.	Any employee / monitoring owner
2. Log and preserve	Open incident record; preserve relevant logs, model versions, configuration and decision evidence.	Incident coordinator / CISO
3. Triage	Assess severity, scope, affected customers, systems and potential harms.	CRO with CISO, DPO and AI / ML Lead
4. Escalate	Notify accountable owners and governance authorities according to severity.	Incident coordinator
5. Contain	Restrict access, disable affected integration or suspend affected AI function where warranted.	CISO / CTO / authorised executive
6. Investigate	Determine root cause and assess technical, privacy, fairness and operational impact.	Relevant technical and control owners
7. Notify and remediate	Determine required internal, customer, supplier and regulatory communications; correct the cause.	DPO / Compliance / Legal / CRO
8. Validate recovery	Test corrective action, reassess risk and obtain approval before resuming use.	Independent reviewer and authorised governance role
9. Learn	Conduct post-incident review and update controls, training and risk register.	CRO / AI Governance Committee

9.4 Role-specific responsibilities

Role	Incident responsibility
CISO	Coordinate cybersecurity investigation, containment, access review and security evidence.
DPO	Assess personal data impact and advise on applicable data protection notification duties.
CRO	Assess enterprise risk, customer impact, severity and risk acceptance implications.
AI / ML Lead	Investigate model behaviour, data quality, version history and technical defects.
Compliance / Legal	Assess applicable legal duties, regulatory engagement and customer communication requirements.
Fraud Operations Manager	Identify affected cases, pause unsafe operational actions and coordinate case review.
Executive Management	Make major business decisions, including suspension or resumption where authorised.

9.5 Return-to-service conditions

An affected function should not resume automatically after a code fix or configuration change. Return to service should require documented root-cause analysis, corrective-action evidence, appropriate validation, updated risk assessment, confirmation that human oversight is functioning and approval by the designated authority. The decision and any remaining limitations should be recorded.

10. AI risk register

10.1 Rating interpretation

The register below is a preliminary risk assessment based on the intended functions described in the case brief. Inherent scores are calculated as likelihood × impact before the proposed controls. Residual scores are estimates after controls are assumed to be implemented and effective. The residual ratings must be revisited after control testing; they must not be presented as achieved results.

ID	Risk	Description	L	I	Inherent	Accountable owner	Proposed controls
AI-01	Algorithmic bias	Training data, labels, sampling or model design may create systematic performance differences across customer groups, leading to inaccurate verification, fraud flags or risk recommendations.	4	5	20 Critical	AI / ML Lead	Assess dataset coverage and provenance; test group-level error rates; review proxy features and labels; independent validation; monitor disparities; remediate or restrict affected use.
AI-02	Privacy and personal data exposure	Excessive collection, incompatible reuse, weak access controls, inappropriate sharing or inadequate retention may expose personal and transaction information.	3	5	15 High	DPO	Map data flows; minimise data; define purposes and retention; enforce least privilege and encryption; review processors and suppliers; assess privacy impacts and incidents.
AI-03	Unfair financial risk decisions	AI recommendations may disadvantage customers without a sufficiently relevant, explainable and justified basis, potentially contributing to financial exclusion.	4	5	20 Critical	CRO	Define fairness criteria; test selection and error rates; review features and thresholds; provide human review and challenge routes; document reasons; remediate unjustified disparities.
AI-04	Lack of transparency and explainability	Customers and staff may be unable to understand material factors, limitations or reasons behind consequential AI outputs.	3	4	12 High	AI / ML Lead	Maintain model and data documentation; provide decision-relevant explanations; log model version and rationale; document limitations; enable review and audit.
AI-05	Insufficient human oversight	Staff may over-rely on AI outputs or lack the training, time, information or authority to challenge recommendations.	3	5	15 High	Fraud Operations Manager	Define review triggers; train reviewers; provide override and escalation authority; record rationale; monitor review quality and customer challenges.
AI-06	Cybersecurity and model manipulation	Attackers may exploit APIs, credentials, infrastructure, data pipelines or model weaknesses to access data or manipulate outputs.	3	5	15 High	CISO	Secure development; strong authentication; least privilege; encryption; vulnerability management; integrity checks; security logging; authorised testing; incident response.
AI-07	Model drift and performance degradation	Changes in customer behaviour, transaction patterns or data quality may reduce model reliability after deployment.	3	4	12 High	AI / ML Lead	Establish baselines; monitor feature and prediction drift; validate periodically; define thresholds; govern retraining; maintain rollback capability.
AI-08	Poor data quality and integrity	Inaccurate, incomplete, stale or inconsistently labelled data may cause incorrect outputs and unreliable model evaluation.	4	4	16 High	Data Governance Lead	Validate schema and ranges; monitor missingness and anomalies; verify sources; maintain lineage; review labels; quarantine suspect data; document quality exceptions.
AI-09	Third-party and supply-chain risk	External AI, cloud, identity or data providers may introduce security, privacy, reliability, concentration or governance weaknesses.	3	4	12 High	CTO	Perform supplier due diligence; contract for security, audit and incident cooperation; restrict access; monitor service performance; plan exit and contingency options.
AI-10	Inadequate incident response and escalation	Unclear ownership, weak detection or untested response procedures may delay containment, customer remediation and required communications.	3	4	12 High	CRO	Approve incident policy; assign contacts; define severity and escalation; preserve evidence; exercise response scenarios; track corrective actions and lessons learned.

10.2 Risk register interpretation

AI-01 and AI-03 are both Critical before treatment because systematic model bias and unjustified financial outcomes could materially affect access to services or trigger harmful investigations. They are related but distinct: bias concerns systematic error or distortion in data or model behaviour, while unfair outcomes concern whether resulting treatment is justified and equitable in context. A disparity is a signal for investigation, not automatic proof of unlawful discrimination.

AI-02 and AI-06 are connected because weak security can expose personal information, while poor data governance can increase the likelihood and impact of security incidents. AI-05 is also significant because technical controls cannot fully protect customers if staff treat model outputs as unquestionable.

Residual scores are conditional estimates. If a proposed control is not implemented, not tested, or does not operate as intended, the inherent risk should not be reduced merely because the control appears in a policy or plan.

11. Deployment gates and risk acceptance

11.1 Proposed risk acceptance rules

Residual rating	Proposed treatment / approval
Low (1–4)	May be accepted by the designated operational risk owner with documented justification and routine monitoring.
Moderate (5–9)	Requires documented acceptance by the relevant risk owner, a treatment plan where appropriate and defined monitoring.
High (10–16)	Requires further mitigation and formal executive-level review; ordinarily blocks the affected use until adequately addressed.
Critical (17–25)	Must not be accepted for production use under the proposed risk appetite; substantial remediation and reassessment are required.

These are proposed internal rules. A numerical rating cannot determine legal permissibility. Legal obligations, customer rights and mandatory controls remain applicable regardless of the score.

11.2 Deployment approval gates

Gate	Minimum evidence	Proposed approver
Governance	Approved AI policy; system inventory; named owners; risk appetite; documented scope.	AI Governance Committee
Data and privacy	Data inventory and flows; quality assessment; access and retention controls; relevant privacy assessment.	DPO / Compliance
Model validation	Performance evidence; validation report; known limitations; change and rollback controls.	AI / ML Lead plus independent reviewer
Fairness	Relevant group analysis; documented investigation of disparities; remediation of material issues.	CRO / AI Governance Committee
Security	Security assessment; access-control evidence; vulnerability remediation; incident readiness.	CISO
Human oversight	Trained reviewers; authority to override; review and escalation procedures; quality assurance.	Fraud Operations Manager
Operational readiness	Monitoring dashboards or reports; incident plan; support process; fallback and rollback.	CTO / CRO

11.3 Deployment recommendation

Based on the case information available, SecureFinance Africa should not be regarded as ready for unrestricted production deployment. The assessment brief does not provide evidence of model validation, fairness testing, privacy controls, security testing, operational monitoring or functioning human oversight. The absence of such evidence is an assessment limitation, not proof that the organisation has no controls.

A limited, controlled pilot may be considered only after the relevant gates have been satisfied. Consequential decisions should remain subject to meaningful human oversight, and the organisation should be able to suspend the affected AI function if material risks emerge. If critical risks remain unresolved, the affected function should not enter production.

12. Implementation roadmap and evidence

12.1 Proposed implementation phases

Phase	Indicative activities	Deliverables / evidence
1. Establish (Weeks 1–2)	Appoint owners; approve interim governance charter; inventory AI use cases and suppliers; define risk appetite.	Governance charter; role matrix; AI system inventory; initial risk register.
2. Map (Weeks 2–4)	Document data flows, intended uses, users, affected stakeholders, decision pathways and dependencies.	System context record; data-flow map; stakeholder and harm analysis.
3. Measure (Weeks 4–7)	Assess data quality, model performance, fairness, explainability, security and privacy controls using appropriate evidence.	Validation plan and reports; fairness analysis; security and privacy findings; risk scores.
4. Manage (Weeks 7–9)	Implement priority controls; establish reviewer procedures; define incident response, monitoring and rollback.	Treatment plan; oversight procedure; incident playbook; monitoring plan.
5. Gate and pilot (After remediation)	Review evidence, approve residual risks, authorise a limited pilot and monitor closely.	Signed deployment decision; pilot restrictions; monitoring reports; review record.

The indicative weeks are planning suggestions, not deadlines in the assessment brief. Actual sequencing should depend on system complexity, available evidence and the severity of identified risks.

12.2 Suggested repository structure

```
aics-201-ai-ethics-governance-assessment/
■■■ README.md
■■■ docs/
■ ■■■ task2_ai_governance_framework.md
■ ■■■ governance_structure.md
■ ■■■ nist_ai_rmf_mapping.md
■ ■■■ human_oversight_framework.md
■ ■■■ incident_escalation_procedure.md
■■■ governance/
■ ■■■ governance_roles.csv
■ ■■■ governance_raci.csv
■ ■■■ ai_deployment_gates.csv
■■■ risk-management/
■ ■■■ ai_risk_register.csv
■ ■■■ risk_scoring_methodology.md
■ ■■■ risk_treatment_plan.csv
■ ■■■ risk_monitoring_plan.csv
■■■ incident-management/
■ ■■■ incident_severity_matrix.csv
■ ■■■ incident_log_template.csv
■■■ evidence/
■■■ governance_structure.png
■■■ risk_matrix.png
■■■ monitoring_evidence/
```

12.3 Reproducibility and evidence quality

The repository should contain editable source files for the tables and diagrams in this report. CSV values should match the PDF. If risk scores are recalculated by code or spreadsheet, the calculation method should be documented and tested. Mermaid diagrams should be retained as source text. Evidence files should be labelled as proposed, illustrative or observed so that synthetic examples and actual organisational evidence are not confused.

13. Limitations and conclusion

13.1 Limitations

Statement	Status
SecureFinance Africa is fictional and the platform supports identity verification, fraud detection and financial risk assessment.	Stated in the assessment brief.
The platform processes personal information and analyses transaction patterns.	Stated in the assessment brief.
Initial deployment is planned in Nigeria; international expansion may occur later.	Stated in the assessment brief.
Specific model architecture, vendors, data fields, training sources, thresholds and automation level.	Not specified; must be confirmed.
CRO, CTO, CISO, DPO, AI Governance Committee and other proposed roles.	Proposed governance design; not confirmed as existing roles.
Risk likelihood, impact and residual ratings.	Preliminary analyst judgements; not empirical results.
Controls listed in the risk register.	Proposed controls; not evidence of implementation.
Actual bias, breach, model drift or operational failure.	Not established by the case brief.

13.2 Conclusion

This report proposes a governance framework for SecureFinance Africa using the four NIST AI RMF functions. It establishes governance responsibilities, a lifecycle-based risk-identification approach, a transparent likelihood-and-impact scoring method, a ten-risk register, mitigation and monitoring arrangements, human oversight requirements and an incident escalation process.

The most significant preliminary risks concern algorithmic bias and potentially unfair financial outcomes. Privacy, human oversight, cybersecurity and data integrity also require priority attention. The proposed residual ratings are conditional on effective implementation and testing of the listed controls.

The recommended decision is to withhold unrestricted production deployment until the organisation can demonstrate that material risks are adequately controlled. A restricted pilot may be considered after deployment gates are met, with meaningful human review of consequential decisions, active monitoring and the ability to suspend unsafe functionality. This approach supports responsible innovation while preserving accountability and the ability to respond when evidence changes.

The report provides a proposed governance design and an auditable starting point for the wider AICS-201 assessment. It does not certify legal compliance or operational readiness.

References

International Cybersecurity & Digital Forensics Academy (ICDFA). (2026). *AICS-201: AI Ethics, Governance & Legal Frameworks — Assessment 01*. Directorate of Training. Assessment brief supplied for this assignment.

National Institute of Standards and Technology (NIST). (2023). *Artificial Intelligence Risk Management Framework (AI RMF 1.0)* (NIST AI 100-1). U.S. Department of Commerce. https://doi.org/10.6028/NIST.AI.100-1

National Institute of Standards and Technology (NIST). (n.d.). *AI Risk Management Framework*. https://www.nist.gov/itl/ai-risk-management-framework

Note: The NIST AI RMF is used here as a voluntary risk-management framework. This report does not treat it as legislation or as a substitute for the legal analysis required in Task 3.

Appendix A — Risk register data dictionary

Field	Definition
risk_id	Unique identifier for each risk.
risk_category	The principal risk theme, such as fairness, privacy, security or operational resilience.
description	A concise statement of the risk event and potential consequence.
likelihood	Preliminary likelihood score from 1 to 5.
impact	Preliminary impact score from 1 to 5.
inherent_score	Likelihood multiplied by impact before proposed controls.
accountable_owner	Role accountable for ensuring that the risk is managed.
proposed_controls	Controls recommended to reduce likelihood or impact.
residual_likelihood / residual_impact	Estimated likelihood and impact after controls are assumed effective.
residual_score	Residual likelihood multiplied by residual impact.
status	Whether a control is proposed, implemented, tested or ineffective. This report uses proposed status.

Appendix B — AI-assisted work declaration template

The assessment brief requires students to declare AI-assisted tools and explain their contribution. Adapt the following statement honestly to reflect the work actually submitted and the applicable institutional rules:

“Generative AI was used as an assistance tool to help structure and draft the proposed AI governance framework, risk register descriptions, monitoring approach and report presentation. The student is responsible for reviewing, validating, adapting and understanding all submitted content, references, assumptions and risk ratings. No real customer records or confidential operational data were provided to the AI tool. The case organisation is fictional, and all proposed roles, controls and risk scores are clearly identified as analytical recommendations unless stated otherwise.”

Before submission, the student should verify the reference details, adapt the declaration to the actual use of AI, ensure that the work complies with ICDFA academic-integrity requirements and be prepared to explain the risk methodology and governance decisions during oral verification.